

CAPSTONE PROJECT DOCUMENTATION

PROJECT 4 :AI IDENTITY SECURITY COMPLIANCE & EVIDENCE REPORT

Screenshot 1: AI Identity Security Policy - Title Page and Table of Contents

This page presents the title page and table of contents of the AI Identity Security Policy. The policy provides a structured view of identity lifecycle management, credential governance, incident response, monitoring and enforcement, and policy review.

Table of Contents	
Section	Page No.
1. Purpose and Scope	3
2. Identity Lifecycle	3
2.1 Identity Provisioning	3
2.2 Authentication and Authorization	3
2.3 Identity Review	4
2.4 Credential Rotation	4
2.5 Identity Decommissioning	4
3. Credential Governance	5
3.1 API Key Management	5
3.2 Short-Lived Credentials	5
3.3 Secret Management	6
3.4 Agent Cryptographic Identity	6
4. Incident Response Playbook	6
4.1 Leaked LLM API Key	7
4.2 Compromised Agent Identity	8
4.3 Prompt Injection and Data Exfiltration	9
5. Monitoring and Enforcement	9
6. Policy Review	10

AI IDENTITY
SECURITY POLICY

AI Identity Security Capstone Project

Organization: AI Identity Security Capstone
Prepared by: PONUGOTI RUCHITHA
Date: 22 August 2026
Version: 1.0

PONUGOTI RUCHITHA • AI Identity Security Capstone

PONUGOTI RUCHITHA • AI Identity Security Capstone

This screenshot shows the Incident Response Playbook portion of the AI Identity Security Policy, including detection signals and containment actions used to limit unauthorized activity and protect AI identities, credentials and data.

4.2 Scenario: Compromised Agent Identity

Detection Signals

- Unexpected scope changes between agent requests.
- An agent requesting write:admin when its approved role only requires read:ai-data.
- Invalid or failed cryptographic signature verification.
- Unexpected API call volume.
- Reuse of expired credentials or tokens.
- Agent actions inconsistent with its assigned role.

29. Containment/Disable the suspected agent identity.

30. Revoke active access and refresh tokens.

31. Remove privileged API scopes.

32. Disable associated API credentials.

33. Block communication from the compromised agent until verification is complete.

Evidence Preservation

- Agent message logs.
- Signature-verification failures.
- Token and authentication events.
- Scope-change events.
- API request logs.
- Relevant timestamps and identity identifiers.

4. Incident Response Playbook

The Incident Response Playbook defines the required response process for incidents involving AI identities, credentials, prompt injection, guardrail failures, and unauthorized data access.

Phase	Required Action
1. Detection	Identify the security signal and affected identity or workflow .
2. Containment	Stop further unauthorized access or disclosure.
3. Evidence Preservation	Preserve logs, prompts, outputs, tokens/identifiers, and timestamps without unnecessarily storing secrets .
4. Notification	Notify the security/identity owner and escalate material impact .

PONUGOTI RUCHITHA • AI Identity Security Capstone

AI IDENTITY SECURITY POLICY | VERSION 1.0

5. Recovery	Rotate/revoke credentials, restore least-privilege access, and validate controls.
6. Post-Incident Review	Document root cause, impact, corrective actions, and lessons learned.

4.1 Scenario: Leaked LLM API Key

Detection Signals

- API key detected in an LLM/model response.
- Secret-scanning alert.
- Credential found in source code or repository.
- Unusual API usage, request volume, or cost.
- Unauthorized requests using the affected credential.
- Security monitoring or anomaly-detection alerts.

Containment

19. Immediately revoke or disable the affected API key.

20. Prevent further use of the credential.

21. Review recent API activity associated with the key.

22. Identify affected applications or agents.

23. Generate a replacement credential after the exposure path is understood.

Evidence Preservation

- Application and API logs.
- Timestamps of suspicious activity.
- Request identifiers where available.

This screenshot demonstrates the mapping of the four NIST AI Risk Management Framework functions: Govern, Map, Measure and Manage. Each function is supported by evidence from the implemented AI identity security controls.

The screenshot shows a Google Sheets document titled "Project_5_Complete_Compliance_Workbook". The spreadsheet contains a table with the following columns: Project, Control / Activity, NIST AI RMF Function, Evidence Artifact, and Status. The data is organized into rows, with the first row being a header. The table lists various security controls and their corresponding NIST AI RMF functions and evidence artifacts. The status for all listed items is "Implemented".

Project	Control / Activity	NIST AI RMF Function	Evidence Artifact	Status
Project 1	AI Identity Threat Modelling using STRIDE	MAP	OWASP Threat Dragon DFD and STRIDE Matrix	Implemented
Project 1	Identity and Trust Boundary Analysis	MAP	Threat Dragon Data Flow Diagram	Implemented
Project 1	Attack Trees For API Key Exfiltration, Agent Spoofing and BAG Poisoning	MAP	Three draw.io Attack Trees	Implemented
Project 1	Risk Scoring and Risk Register	MEASURE	Likelihood x Impact Risk Register	Implemented
Project 1	MITRE ATLAS Attack Mapping	MAP	MITRE ATLAS Technique Mapping	Implemented
Project 2	OAuth 2.0 Authorization Code + PKCE	GOVERN	Auth0 Application Configuration and JWT Evidence	Implemented
Project 2	Role and Scope-Based Authorization	GOVERN	read:ai-data and write:admin Scope Testing	Implemented
Project 2	MFA and Auth0 Attack Protection	MANAGE	MFA and Auth0 Attack Protection Configuration	Implemented
Project 2	Short-Lived Credential Management	MANAGE	Credential Rotation Test Output	Implemented
Project 2	Auth0 Actions and Custom Identity Claims	GOVERN	Post-Login Action and agent_id JWT Claim	Implemented
Project 3	Indirect Prompt Injection Testing	MEASURE	Red Team Attack Logs and Payload Evidence	Implemented
Project 3	Agent Identity Spoofing Testing	MEASURE	Agent Spoofing Attack Evidence	Implemented
Project 3	System Prompt Extraction Testing	MEASURE	Prompt Extraction Test Results	Implemented
Project 3	RAG Poisoning and MCP Tool Abuse Testing	MEASURE	RAG/MCP Poisoning Attack Evidence	Implemented
Project 3	CVSS and Attack Success Measurement	MEASURE	CVSS Findings Table and Attack Success Matrix	Implemented
Project 4	Input Prompt Injection Guardsrails	MANAGE	input_guardrail_test.py Output	Implemented
Project 4	JWT Credential Output Reduction	MANAGE	jwt_output_guardrail.py Output	Implemented
Project 4	Ed25519 Cryptographic Agent Identity Binding	MANAGE	ed25519_keygen.py and Message Verification Output	Implemented
Project 4	Refresh Token Rotation	MANAGE	refresh_token_rotation_test.py Output	Implemented
Project 4	Auth0 Risk-Based Login Blocking	MANAGE	Auth0 Action Blocked Login Evidence	Implemented
Project 4	Anomaly Detection and Security Alerts	MEASURE	anomaly_detection.py Alert Output	Implemented
Project 4	Before/After Attack Success Comparison	MEASURE	before_after_comparison.py Results	Implemented

Screenshot 4 : OWASP LLM Top 10 Mapping

This screenshot maps the OWASP LLM Top 10 security risks to the attacks identified in Project 3 and the corresponding defensive controls implemented in Project 4, with evidence artifacts and implementation status.

Project_5_Complete_Compliance_Workbook

File Edit View Insert Format Data Tools Extensions Help

100% 123 Roboto 10 B

Share Upgrade

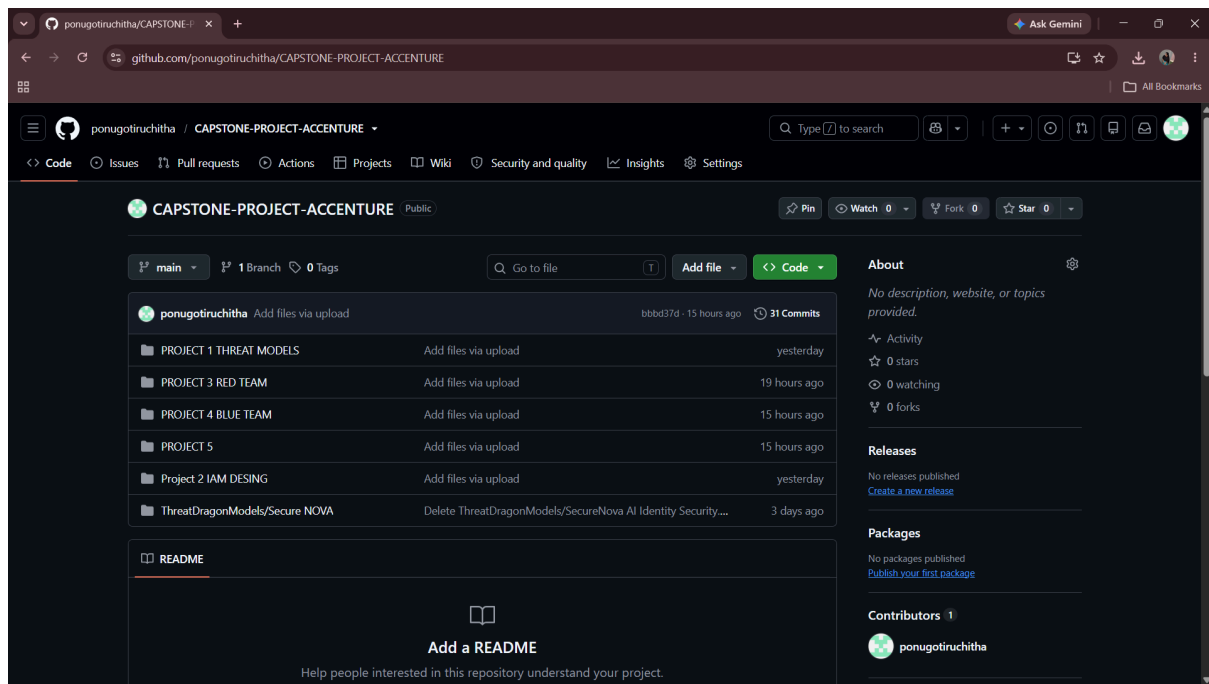
Project

	A	B	C	D	E	F	G	H	I	J	K	L
	OWASPMapping											
1	Project	Control / Activity	OWASP LLM Top 10 Risk	Evidence Artifact	Status							
2	Project 3 & 4	Indirect Prompt Injection Attack and Input Guardrail	LLM01: Prompt Injection	Project 3 attack evidence + input_guardrail_test.py output	Implemented							
3	Project 3 & 4	System Prompt Extraction Attack and Output Protection	LLM06: Sensitive Information Disclosure	Prompt extraction test results + jwt_output_guardrail.py output	Implemented							
4	Project 3 & 4	RAG Poisoning and MCP Tool Abuse Guardrail	LLM07: Insecure Plugin Design	RAG/MCP attack evidence + Project 4 input/tool guardrail output	Implemented							
5	Project 4	LLM API Volume Spike Detection and Security Alerting	LLM10: Unbounded Consumption	anomaly_detection.py real HTTP request spike output	Implemented							
6	Project 3 & 4	Agent Identity Spoofing and Cryptographic Identity Validation	LLM01: Prompt Injection	Spoofing attack evidence + Ed25519 signature verification output	Implemented							
7												
8												
9												
10												
11												
12												
13												
14												
15												
16												
17												
18												
19												
20												
21												
22												
23												
24												
25												

NIST AI RMF OWASP LLM Top 10 Risk Priority Matrix Top 5 Recommendations

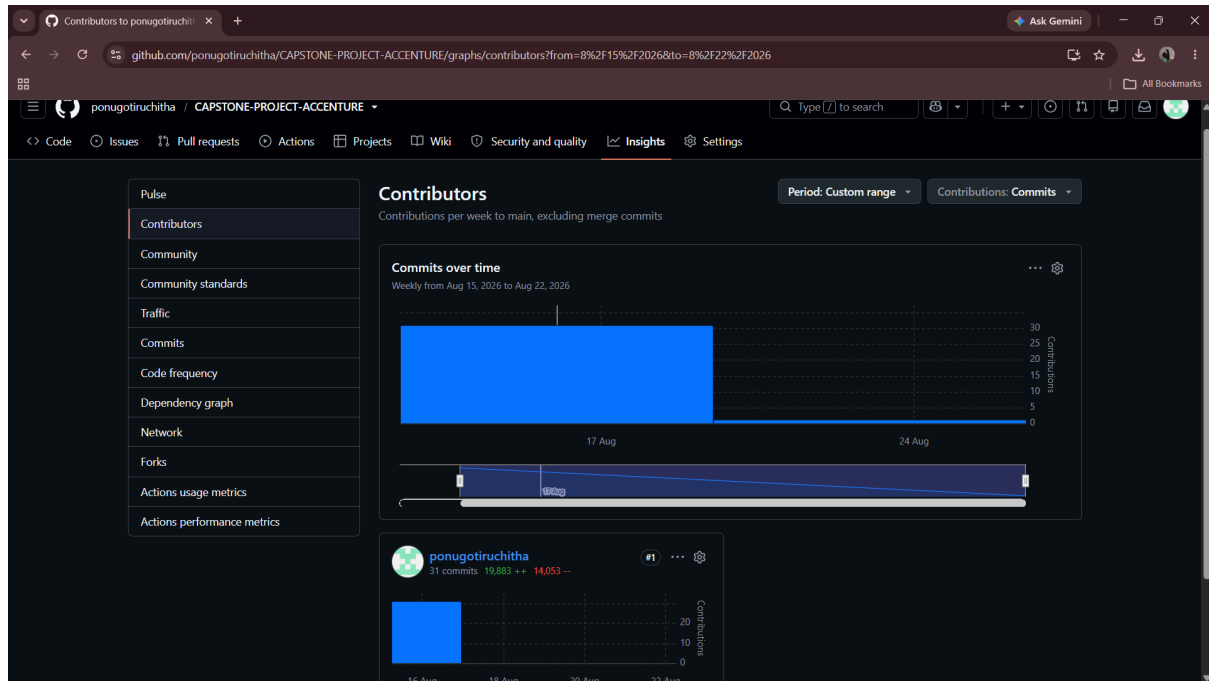
Screenshot 5:GitHub Repository - Five Project Folders

This screenshot displays the GitHub repository structure with the five project folders visible in the repository file tree. It provides evidence that the capstone project components were organized and maintained in a single repository.



Screenshot 6: GitHub Commit History and Contributions

This screenshot shows GitHub contribution activity and commit history for the capstone project. The contribution graph provides evidence of development activity and project progress.



Screenshot 7: Risk Priority Matrix with CVSS Scores

This screenshot presents the AI Identity Security risk priority matrix containing the identified security findings. The findings are prioritized using CVSS scores together with likelihood and impact to support remediation decisions.

Project_5_Complete_Compliance_Workbook

File Edit View Insert Format Data Tools Extensions Help

100% 123 Default... 12 B I A

AI IDENTITY SECURITY — RISK PRIORITY MATRIX

Findings ID	Security Finding	CVSS Score	Severity	Priority
F-01	Indirect Prompt Injection	9.1	Critical	Critical
F-02	Agent Identity Spoofing	8.2	High	High
F-03	Two-Agent Identity Spoofing	8.2	High	High
F-04	System Prompt Leakage	5.3	Medium	Medium
F-05	RAG Poisoning / MCP Tool Invocation Abuse	8.2	High	High

SECTION 2: RISK PRIORITY MATRIX

Likelihood \ Impact	Low	Medium	High
High		F-01 (9.1) F-03 (8.2) F-05 (8.2)	
Medium		F-04 (5.3)	
Low			

NIST AI RMF OWASP LLM Top 10 Risk Priority Matrix Top 5 Recommendations

Screenshot 8:Top 5 Security Recommendations

This screenshot presents the Top 5 Security Recommendations derived from the overall project findings. The recommendations include effort estimates, the security issue addressed, business rationale and expected security benefit.

Project_5_Complete_Compliance_Workbook						
SECURENOVA AI IDENTITY SECURITY — TOP 5 RECOMMENDATIONS						
1	SECURENOVA AI IDENTITY SECURITY — TOP 5 RECOMMENDATIONS					
2						
3	Priority	Recommendation	Security Issue Addressed	Effort Estimate	Business Rationale	Expected Security Benefit
4	1	Enforce Short-Lived Credentials and Automated Rotation	Long-lived or exposed credentials can be reused by attackers.	Medium	Reduces the business impact of credential theft and limits the time window for replay or unauthorized access.	Reduced credential exposure and replay risk.
5	2	Implement Strong AI Input and Output Guardrails	Prompt injection, system prompt extraction, and sensitive credential disclosure.	Medium	Protects customer data and internal system information while reducing malicious AI behavior.	Blocks malicious instructions and redacts sensitive information.
6	3	Enforce Cryptographic Agent Identity Verification	Agent identity spoofing and message tampering.	High	Prevents attackers from impersonating trusted AI agents and protects agent-to-agent communication.	E2E25519 signing and verification reject forged or unauthenticated messages.
7	4	Apply Least-Privilege Access and Continuous Scope Monitoring	Unexpected privilege escalation and unauthorized scope changes.	Medium	Limits potential damage from compromised user, agent, or machine identities.	Unauthorized scope changes can be detected and high-risk permissions restricted.
8	5	Strengthen AI Security Monitoring and Incident Response	Delayed detection of attacks, abnormal API activity, and token replay.	Medium	Early detection reduces downtime, investigation costs, and potential customer impact.	Detects API volume spikes, suspicious identity activity, and supports faster containment.
9						
10						
11						
12						
13						
14						
15						
16						
17						
18						
19						
20						
21						
22						
23						
24						